

PHISHING EMAIL DETECTION & AWARENESS REPORT

Prepared by: Titus Joshua

Role: SOC Analyst

Date: 12th April, 2026

Classification: INTERNAL USE ONLY

1. Executive Summary

Phishing remains one of the most prevalent and damaging cyber threats facing organizations today. Attackers craft deceptive emails that impersonate trusted brands and services to trick users into revealing credentials, connecting crypto wallets, or clicking malicious links.

This report presents the analysis of two real-world phishing email samples collected from a public honeypot repository. Each sample was examined using industry-standard tools including Google Admin Toolbox Message Header Analyzer and Thunderbird email client. Findings are documented with supporting evidence and accompanied by actionable prevention guidelines for employees.

Metric	Details
Samples Analyzed	2
Risk Classification	Both classified as HIGH RISK - PHISHING
Attack Types Identified	Crypto Wallet Drain, Microsoft Account Impersonation
Tools Used	Thunderbird, Google Admin Toolbox, MXToolbox
MITRE ATT&CK Mapping	T1566.002 - Spearphishing Link

2. Analysis Methodology

Each phishing email was analyzed following a structured triage process used by SOC analysts during phishing investigations. The process consisted of five stages:

- Sample Collection - Real phishing emails sourced from `rf-peixoto/phishing_pot`, a public honeypot repository on GitHub containing emails captured in the wild.
- Email Rendering - Each `.eml` file was opened in Mozilla Thunderbird with remote content blocked to safely view the email as a victim would see it.
- Header Analysis - Email headers were submitted to the Google Admin Toolbox Message Header Analyzer to visualize the mail routing path and inspect SPF, DKIM, and DMARC authentication results.
- Indicator Identification - Five key checkpoints were assessed: sender domain, Reply-To address, urgency language, embedded URLs, and email greeting.
- Risk Classification - Each email was classified as Safe, Suspicious, or Phishing based on the weight of evidence collected.

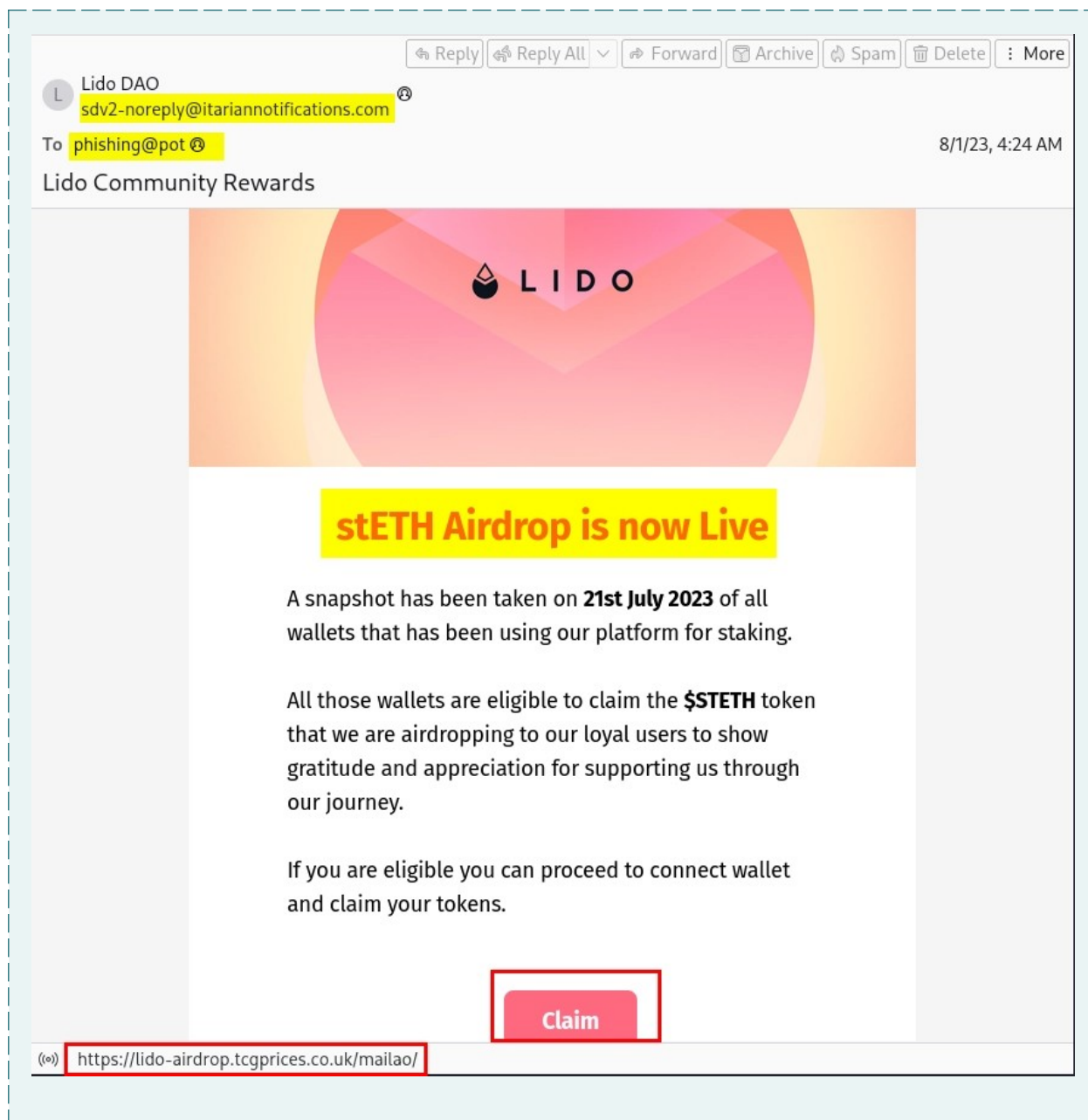
3. Email Sample 1: Crypto Airdrop Phishing

3.1 Email Overview

Field	Value
From (Display)	Lido DAO
From (Actual)	sdv2-noreply@itariannotifications.com
To	phishing@pot
Subject	Lido Community Rewards
Date	August 1, 2023, 4:24 AM GMT+3
Originating IP	20.240.44.186 (Azure cloud VM)
Malicious URL	https://lido-airdrop.tcgprices.co.uk/mailao/
Hidden Page Title	copy_metamask

3.2 Rendered Email (Exhibit A)

The screenshot below shows the email as rendered in Mozilla Thunderbird with remote content blocked. Note the Lido branding used to appear legitimate.



3.3 Header Analysis (Exhibit B)

The screenshot below shows the output from Google Admin Toolbox Message Header Analyzer. Note the email routing path originating from an unknown source through the attacker's mail server.

MessageId	20230801012403.CACFBE32FF@mail.itariannotifications.com				
Created at:	8/1/2023, 4:24:03 AM GMT+3 (Delivered after 2 sec)				
From:	Lido DAO <sdv2-noreply@itariannotifications.com>				
To:	phishing@pot				
Subject:	Lido Community Rewards				
SPF:	pass with IP Unknown! Learn more				
DKIM:	pass with domain Unknown! Learn more				
DMARC:	pass Learn more				

#	Delay	From *	To *	Protocol	Time received
0		unknown	→ mail.itariannotifications.com		8/1/2023, 4:24:03 AM GMT+3
1	1 sec	mail.itariannotifications.com	→ localhost	ESMTP	8/1/2023, 4:24:04 AM GMT+3
2		localhost	→ mail.itariannotifications.com	ESMTP	8/1/2023, 4:24:04 AM GMT+3
3		mail.itariannotifications.com	→ localhost	ESMTP	8/1/2023, 4:24:04 AM GMT+3
4		localhost	→ mail.itariannotifications.com	ESMTP	8/1/2023, 4:24:04 AM GMT+3
5	1 sec	DBBEURO5FT041.eop-eur05.prod.protection.outlook.com	→ DB7PR05CA0007.outlook.office365.com		8/1/2023, 4:24:05 AM GMT+3

3.4 Phishing Indicators Identified

#	Indicator	Finding	Verdict
1	Sender Domain	sdv2-noreply@itariannotifications.com - unrelated to lido.fi	PHISHING
2	Display Name Spoofing	Claims to be Lido DAO but sends from unrelated domain	PHISHING
3	Malicious URL	Claim button links to lido-airdrop.tcgprices.co.uk - not lido.fi	PHISHING
4	Hidden Page Title	HTML source contains title copy_metamask - wallet theft tool	PHISHING
5	Remote Content Blocked	Thunderbird auto-blocked images - consistent with tracking pixels	SUSPICIOUS
6	SPF/DKIM Authentication	Passes for itariannotifications.com, NOT for lido.fi	SUSPICIOUS
7	Microsoft SCL Score	Rated 6/9 by Microsoft spam filter - flagged as suspicious	SUSPICIOUS
8	Generic Recipient	Sent to phishing@pot - no personalization	SUSPICIOUS

3.5 How This Attack Works

This is a cryptocurrency wallet drain attack. The attacker impersonates Lido DAO - a legitimate Ethereum staking platform - and claims the victim is eligible for a free \$stETH token airdrop. The email uses Lido's real logo and branding to appear credible.

When the victim clicks the Claim button, they are taken to a fake website designed to look like Lido's platform. The site prompts the victim to connect their crypto wallet (e.g., MetaMask). Once connected, the attacker's smart contract silently drains all tokens from the wallet. This is confirmed by the hidden HTML page title `copy_metamask` embedded in the email's source code.

3.6 Risk Classification

Classification	Confidence	Attack Type	MITRE ATT&CK
PHISHING	HIGH	Crypto Wallet Drain / Brand Impersonation	T1566.002 - Spearphishing Link

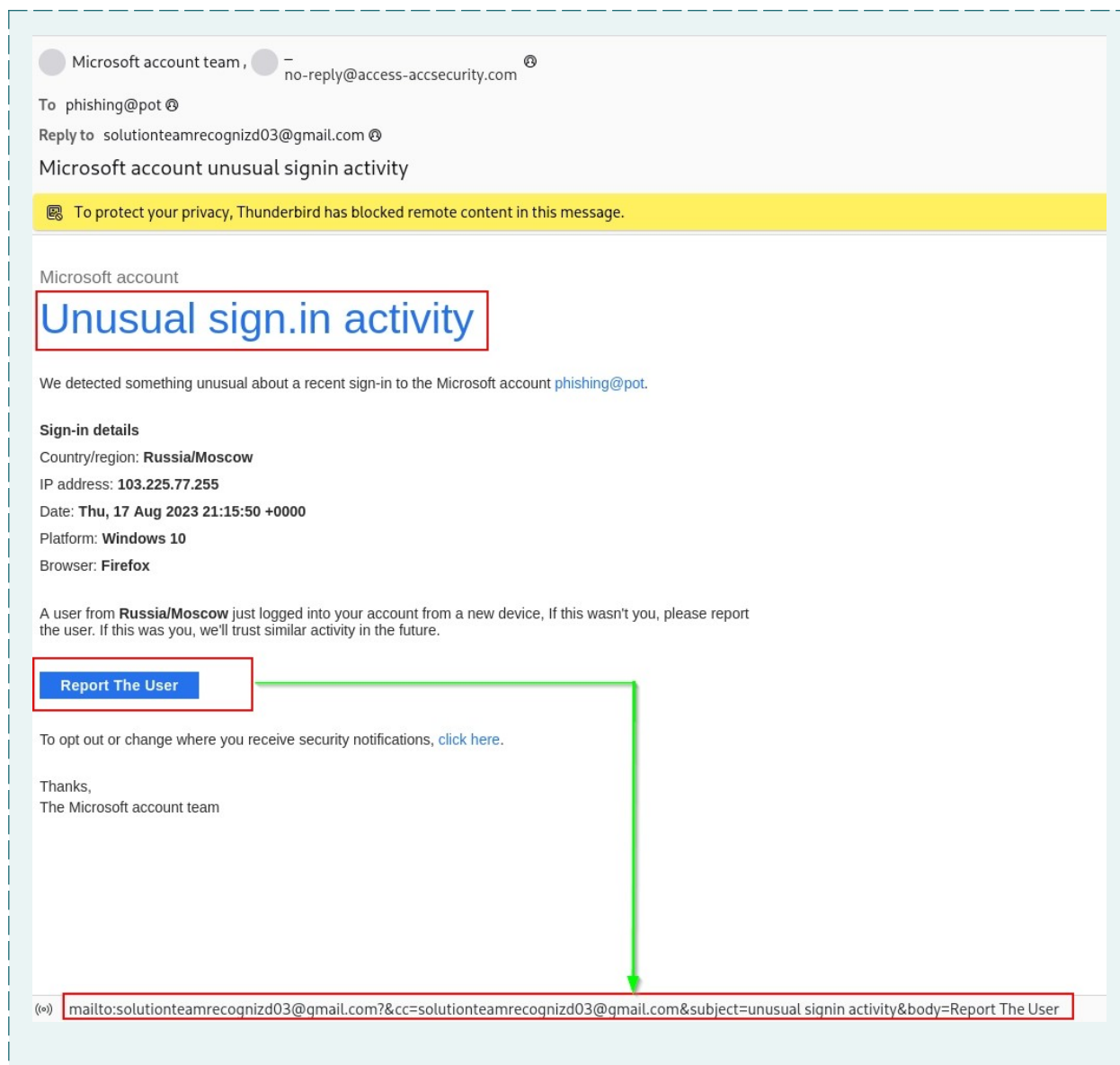
4. Email Sample 2: Microsoft Account Impersonation

4.1 Email Overview

Field	Value
From (Display)	Microsoft account team
From (Actual)	no-reply@access-accsecurity.com
Reply-To	solutionteamrecognizd03@gmail.com
To	phishing@pot
Subject	Microsoft account unusual signin activity
Date	August 18, 2023, 12:15 AM GMT+3
SPF / DKIM / DMARC	None / None / permerror
Button Destination	mailto:solutionteamrecognizd03@gmail.com

4.2 Rendered Email (Exhibit C)

The screenshot below shows the email as rendered in Mozilla Thunderbird. The email mimics a legitimate Microsoft security alert, complete with signin details from Russia/Moscow to create fear and urgency.



4.3 Header Analysis (Exhibit D)

The screenshot below shows the header analysis result. Unlike Sample 1, this email has no SPF, no DKIM, and a DMARC permanent error - all major authentication failures.

Google Admin Toolbox Messageheader

Messageid	aead2b08-156e-41d2-a68c-b070c5447dd3@MW2NAM10FT080.eop-nam10.prod.protection.outlook.com
Created at:	8/18/2023, 12:15:50 AM GMT+3 (Delivered after 1 sec)
From:	Microsoft account team _<no-reply@access-accsecurity.com>
To:	phishing@pot
Subject:	Microsoft account unusual signin activity
SPF:	none Learn more
DKIM:	none Learn more
DMARC:	permerror Learn more

#	Delay	From *	To *	Protocol	Time received
0	1 sec	MW2NAM10FT080.eop-nam10.prod.protection.outlook.com	→ MW4PR04CA0093.outlook.office365.com		8/18/2023, 12:15:51 AM GMT+3

4.4 Phishing Indicators Identified

#	Indicator	Finding	Verdict
1	Sender Domain	no-reply@access-accsecurity.com - not microsoft.com	PHISHING
2	Reply-To Address	solutionteamrecognizd03@gmail.com - Microsoft never uses Gmail	PHISHING
3	Button Destination	Report The User button emails the attacker's Gmail directly	PHISHING
4	SPF	None - no SPF record configured on sending domain	PHISHING
5	DKIM	None - no digital signature on this email	PHISHING
6	DMARC	permerror - permanently misconfigured, major red flag	PHISHING
7	Fear-based Language	Unusual signin from Russia/Moscow - designed to panic the victim	SUSPICIOUS
8	Generic Recipient	Sent to phishing@pot - no real name used	SUSPICIOUS

4.5 How This Attack Works

This is a social engineering attack that exploits fear of account compromise. The attacker impersonates Microsoft's security team and claims an unauthorized login from Russia has been detected on the victim's account. The fabricated signin details (IP address, country, browser, platform) are designed to appear credible and provoke panic.

The Report The User button does not link to Microsoft - it opens the victim's email client and sends a pre-composed message to the attacker's Gmail address. The attacker collects these replies to confirm active email addresses, gather victim information, or escalate to further attacks such as credential phishing or account takeover.

4.6 Risk Classification

Classification	Confidence	Attack Type	MITRE ATT&CK
PHISHING	HIGH	Microsoft Impersonation / Social Engineering	T1566.002 - Spearphishing Link

5. Comparative Analysis

The table below summarizes the key differences and similarities between the two phishing samples analyzed.

Attribute	Sample 1 - Lido DAO	Sample 2 - Microsoft
Attack Type	Crypto wallet drain	Account impersonation
Sender Domain	itariannotifications.com	access-accsecurity.com
SPF	Pass (own domain)	None
DKIM	Pass (own domain)	None
DMARC	Pass	permerror
Reply-To Mismatch	No	Yes - Gmail address
Malicious URL	Yes - fake Lido site	Yes - attacker Gmail
Urgency Tactic	Free reward lure	Fear of account breach
Branding Used	Lido DAO logo	Microsoft styling
Risk Level	HIGH - PHISHING	HIGH - PHISHING

6. Prevention Guidelines for Employees

The following guidelines should be followed by all staff to identify and avoid phishing attacks.

6.1 How to Spot a Phishing Email

Check This	Ask Yourself
Sender address	Does the domain match the real company? e.g. microsoft.com not access-accsecurity.com
Reply-To address	Is it different from the sender? Legitimate companies do not use Gmail for replies
Links and buttons	Hover over any link before clicking - does the URL match the brand?
Urgency and threats	Is it pressuring you to act immediately? Panic is the attacker's tool
Greeting	Does it address you by name? Generic greetings like Dear User are a red flag
Attachments	Were you expecting this file? Never open unexpected attachments
Authentication	Did your email client warn you about remote content or failed checks?

6.2 Do's and Don'ts

DO	DO NOT
Verify the sender's full email address	Click links in unexpected emails
Hover over links before clicking	Enter credentials from an email link
Report suspicious emails to your security team	Connect your crypto wallet from an email prompt
Check with the sender through a separate channel	Reply to suspicious emails
Use multi-factor authentication on all accounts	Unblock remote content in suspicious emails
When in doubt, delete the email	Forward phishing emails without warning recipients

6.3 What To Do If You Clicked a Link

- Disconnect your device from the internet immediately
- Do not enter any credentials or personal information on the page
- Report the incident to your IT/Security team right away
- Change your passwords for any accounts that may be affected
- If a crypto wallet was connected, transfer assets to a new wallet immediately

7. Conclusion

Both phishing emails analyzed in this report demonstrate sophisticated social engineering techniques used to deceive victims. Sample 1 used professional branding and a credible-looking email infrastructure to lure crypto wallet holders, while Sample 2 exploited fear of account compromise to redirect victims to an attacker-controlled Gmail address.

Key takeaways from this analysis are: passing SPF and DKIM authentication does not guarantee an email is legitimate - attackers can set up their own authenticated domains. Failed authentication (none, permerror) is an immediate red flag. The most reliable indicator remains the mismatch between the displayed sender name and the actual sending domain.

Organizations should invest in ongoing phishing awareness training, enforce email authentication policies (SPF, DKIM, DMARC), and deploy email security gateways that flag suspicious messages before they reach end users.